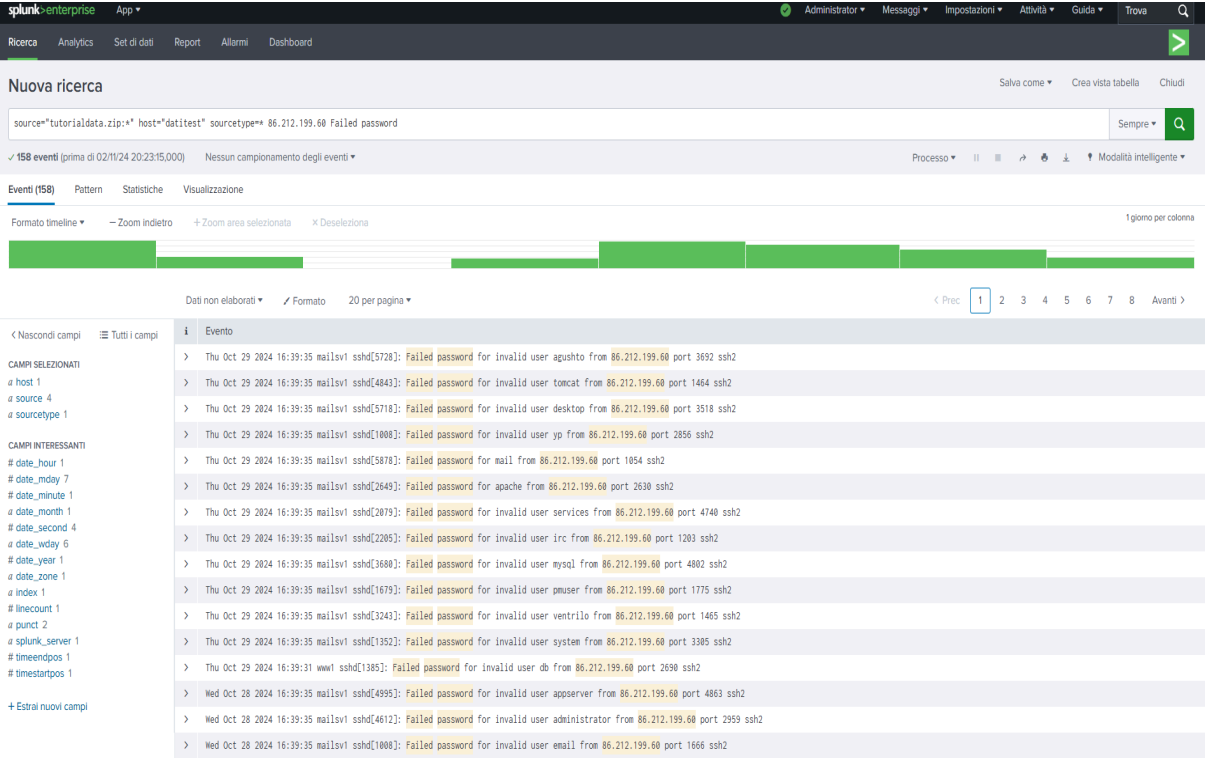




Sulla base dello screenshot di Splunk Enterprise che hai fornito, ecco alcune osservazioni e conclusioni derivanti dall'analisi dei log utilizzando l'intelligenza artificiale:

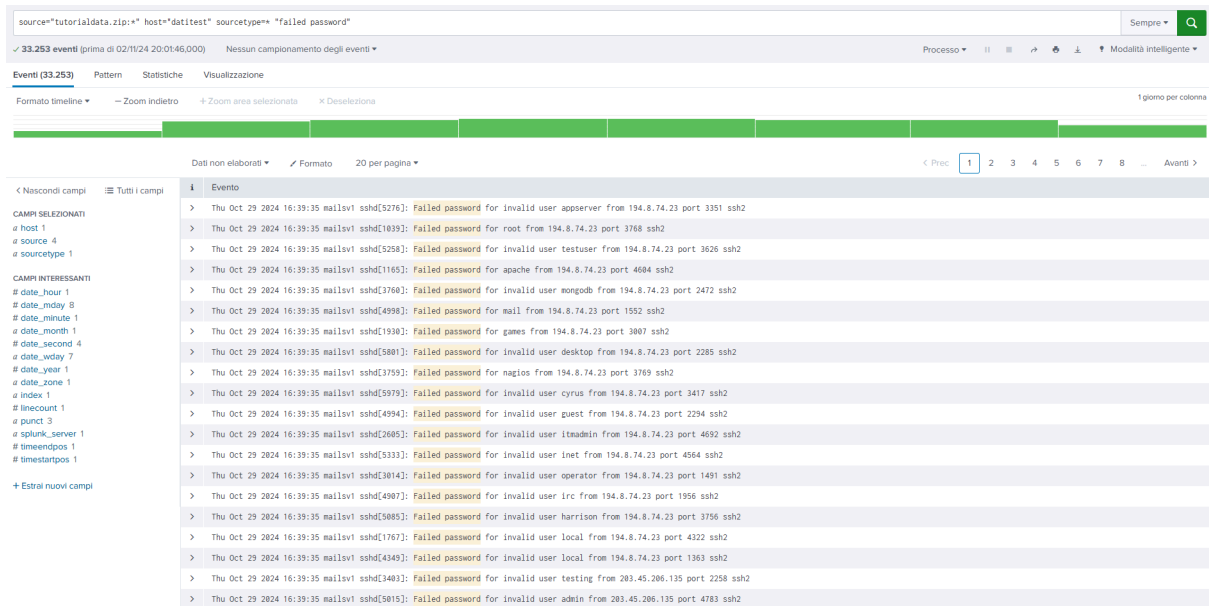
- Fonte dell'attacco:** Tutti i tentativi di accesso falliti provengono da un unico indirizzo IP, **86.212.199.60**. Questo suggerisce fortemente che sia in corso un attacco brute-force mirato al tuo servizio SSH.
- Utenti presi di mira:** I log mostrano tentativi di accesso a una varietà di utenti non validi come **agushto**, **tomcat**, **desktop**, **yp**, **mail**, ecc. Questo indica che l'attaccante sta provando con un elenco di nomi utente comuni o generati automaticamente, cercando di trovare un accesso valido.
- Frequenza dell'attacco:** La distribuzione temporale dei tentativi, visibile attraverso la timeline, suggerisce che gli attacchi sono abbastanza continui, il che potrebbe indicare un attacco automatizzato piuttosto che uno manuale.
- Porte SSH utilizzate:** Gli attacchi sembrano mirare a diverse porte SSH (come **3692**, **1464**, **3518**, ecc.), il che potrebbe essere un tentativo di aggirare eventuali regole di firewall che limitano gli accessi su porte specifiche.

Raccomandazioni

- Bloccare l'indirizzo IP sospetto:** Può essere utile bloccare l'indirizzo IP **86.212.199.60** temporaneamente o definitivamente, a seconda delle politiche di sicurezza della tua rete.
- Implementare misure di protezione:** Considera l'uso di meccanismi di difesa come Fail2ban per bloccare automaticamente gli indirizzi IP dopo un certo numero di tentativi falliti.

- **Rafforzare le credenziali di accesso:** Assicurati che tutti gli account utilizzino password forti e, se possibile, abilita l'autenticazione a due fattori (2FA).
- **Analisi del traffico:** Può essere utile analizzare ulteriormente il traffico proveniente da questo IP per determinare se ci sono altri segni di attività sospetta.

Questa analisi suggerisce un attacco concentrato e automatizzato, quindi è importante agire rapidamente per proteggere i sistemi.



Dall'analisi del secondo screenshot di Splunk Enterprise che hai fornito, emergono le seguenti osservazioni e conclusioni:

1. Attività sospetta e probabile attacco brute-force

- **Alto numero di eventi:** Sono stati registrati ben **33.253 eventi** legati a tentativi di accesso falliti. Questo suggerisce fortemente un attacco brute-force, dove un attaccante cerca ripetutamente di accedere utilizzando diversi nomi utente e password.
- **Tentativi da IP specifico:** Molti di questi tentativi provengono da un IP sospetto, **194.8.74.23**, il che potrebbe indicare un attacco automatizzato da una singola sorgente. Un altro IP (**203.45.206.135**) appare in alcuni eventi, suggerendo potenzialmente più fonti di attacco.

2. Vari utenti presi di mira

- Gli attacchi stanno cercando di accedere a una vasta gamma di utenti, tra cui **appserver**, **root**, **apache**, **mongodb**, **mail**, **admin**, e molti altri. L'attaccante sta provando un elenco di utenti comuni o importanti, aumentando la probabilità di trovare un account vulnerabile.
- Il fatto che vengano utilizzati nomi utente specifici e diversificati indica un attacco molto ben preparato, probabilmente supportato da un database di credenziali comuni o da un attacco mirato.

3. Porte SSH diverse

- I tentativi di connessione utilizzano anche porte SSH differenti, come 3351, 3768, 4604, 1552, ecc. Questo approccio può essere un tentativo di eludere le regole del firewall o di evitare il rilevamento bloccando il traffico su porte non standard.

4. Distribuzione temporale

- Il grafico temporale suggerisce che gli attacchi sono distribuiti in modo continuativo. Questo aspetto implica che l'attacco è molto probabilmente automatizzato, con uno script o un tool che esegue i tentativi in modo ciclico.

Raccomandazioni per la sicurezza

1. **Bloccare gli IP sospetti:** Considera di bloccare l'IP 194.8.74.23 (e altri coinvolti, come 203.45.206.135) tramite il firewall per prevenire ulteriori tentativi.
2. **Implementare meccanismi di difesa:**
 - Utilizzare strumenti come **Fail2ban** per bloccare automaticamente gli indirizzi IP dopo un certo numero di tentativi di login falliti.
 - Considerare l'utilizzo di un **sistema di rilevamento delle intrusioni (IDS)** per monitorare attività sospette.
3. **Migliorare la sicurezza SSH:**
 - Disabilitare l'accesso SSH per l'utente **root** e limitare l'accesso solo agli utenti essenziali.
 - Utilizzare **chiavi SSH** invece di password per un'autenticazione più sicura.
4. **Abilitare l'autenticazione a due fattori (2FA):** Questa misura fornisce un ulteriore livello di protezione, rendendo l'accesso più difficile per un attaccante.
5. **Verificare eventuali compromissioni:** Controlla i sistemi per assicurarti che non ci siano state violazioni o accessi riusciti da parte degli attaccanti.

Questa situazione richiede una risposta immediata per proteggere i sistemi critici.

source=tutorialdata.zip:* host=datitest* sourcetype= session opened djohnson		Sempre	
✓ 1.269 eventi (prima di 02/11/24 20:16:24,000) Nessun campionamento degli eventi		Processo	
Eventi (1.269) Pattern Statistiche Visualizzazione			
Formato timeline - Zoom indietro + Zoom area selezionata X Deselezione		1 giorno per colonna	
Dati non elaborati Formato 20 per pagina < Prec 1 2 3 4 5 6 7 8 ... Avanti >			
< Nascondi campi Tutti i campi CAMPI SELEZIONATI # host 1 # source 4 # sourcetype 1 CAMPI INTERESSANTI # date_hour 1 # date_minute 8 # date_month 1 # date_second 4 # date_wday 7 # date_year 1 # date_zone 1 # index 1 # linecount 1 # offset 2 # splunk_server 1 # timestamp 1 # uid 1 + Estrai nuovi campi		Evento > Thu Oct 29 2024 16:39:35 mailsv1 sshd[60445]: pam_unix(sshd:session): session opened for user djohnson by (uid=0) > Thu Oct 29 2024 16:39:35 mailsv1 sshd[87066]: pam_unix(sshd:session): session opened for user djohnson by (uid=0) > Thu Oct 29 2024 16:39:35 mailsv1 sshd[5860]: pam_unix(sshd:session): session opened for user djohnson by (uid=0) > Thu Oct 29 2024 16:39:35 mailsv1 sshd[77798]: pam_unix(sshd:session): session opened for user djohnson by (uid=0) > Thu Oct 29 2024 16:39:35 mailsv1 sshd[54908]: pam_unix(sshd:session): session opened for user djohnson by (uid=0) > Thu Oct 29 2024 16:39:35 mailsv1 su: pam_unix(su:session): session opened for user root by djohnson(uid=0) > Thu Oct 29 2024 16:39:35 mailsv1 sshd[58738]: pam_unix(sshd:session): session opened for user djohnson by (uid=0) > Thu Oct 29 2024 16:39:35 mailsv1 sshd[68748]: pam_unix(sshd:session): session opened for user djohnson by (uid=0) > Thu Oct 29 2024 16:39:35 mailsv1 sshd[97536]: pam_unix(sshd:session): session opened for user djohnson by (uid=0) > Thu Oct 29 2024 16:39:35 mailsv1 sshd[73063]: pam_unix(sshd:session): session opened for user djohnson by (uid=0) > Thu Oct 29 2024 16:39:35 mailsv1 sshd[53381]: pam_unix(sshd:session): session opened for user djohnson by (uid=0) > Thu Oct 29 2024 16:39:35 mailsv1 su: pam_unix(su:session): session opened for user root by djohnson(uid=0) > Thu Oct 29 2024 16:39:35 mailsv1 su: pam_unix(su:session): session opened for user root by djohnson(uid=0) > Thu Oct 29 2024 16:39:35 mailsv1 su: pam_unix(su:session): session opened for user root by djohnson(uid=0) > Thu Oct 29 2024 16:39:35 mailsv1 sshd[54527]: pam_unix(sshd:session): session opened for user djohnson by (uid=0) > Thu Oct 29 2024 16:39:35 mailsv1 sshd[80248]: pam_unix(sshd:session): session opened for user djohnson by (uid=0) > Thu Oct 29 2024 16:39:35 mailsv1 sshd[50926]: pam_unix(sshd:session): session opened for user djohnson by (uid=0) > Thu Oct 29 2024 16:39:35 mailsv1 sshd[2208]: pam_unix(sshd:session): session opened for user djohnson by (uid=0) > Thu Oct 29 2024 16:39:35 mailsv1 sshd[61374]: pam_unix(sshd:session): session opened for user djohnson by (uid=0) > Thu Oct 29 2024 16:39:35 mailsv1 sshd[63011]: pam_unix(sshd:session): session opened for user djohnson by (uid=0)	

Analizzando lo screenshot che mostra i log in Splunk relativi alle sessioni aperte per l'utente **djohnson**, possiamo trarre alcune osservazioni significative:

1. Accessi ripetuti per l'utente djohnson

- Sono stati registrati **1.269 eventi** in cui la sessione è stata aperta per l'utente **djohnson**. Questo volume di eventi è anomalo e potrebbe indicare una potenziale compromissione dell'account o un'attività sospetta.
- La costanza e il numero di sessioni aperte suggeriscono l'uso di script automatizzati o una connessione costante e ripetuta per scopi sospetti.

2. Sessioni aperte con privilegi elevati

- Alcuni log mostrano che l'utente **djohnson** ha aperto sessioni come **root** con **uid=0**. Questo è particolarmente preoccupante, poiché implica che l'attività potrebbe consentire accesso con privilegi amministrativi, esponendo l'intero sistema a rischi critici.
- Gli eventi di elevazione dei privilegi (da **djohnson** a **root**) possono indicare un abuso dell'account per eseguire operazioni amministrative o per compromettere ulteriormente il sistema.

3. Assenza di variazione temporale visibile

- Dallo screenshot non è evidente una distribuzione temporale ampia, ma il fatto che ci siano molti eventi consecutivi con lo stesso timestamp suggerisce un accesso massiccio concentrato in un breve intervallo di tempo. Potrebbe essere parte di un attacco continuo o un tentativo di esecuzione rapida di comandi da parte di un aggressore.

Possibili Conclusioni

1. **Potenziale compromissione dell'account `djohnson`:** L'accesso continuo e ripetuto dell'utente `djohnson` potrebbe essere segnale di un account compromesso. È necessario esaminare se questo comportamento è legittimo o se indica un attacco in corso.
 2. **Attività sospetta con elevazione dei privilegi:** L'uso dei privilegi `root` da parte di `djohnson` è preoccupante. Un utente malintenzionato potrebbe aver ottenuto l'accesso e sta tentando di eseguire comandi critici o di manipolare il sistema.
 3. **Automatizzazione o script malevolo:** Il volume e la velocità degli eventi indicano un'attività probabilmente automatizzata, che potrebbe derivare da un malware o da uno script che esegue azioni non autorizzate.
-

Raccomandazioni di sicurezza

1. **Controllo dell'account `djohnson`:**
 - Verificare immediatamente l'attività dell'account `djohnson` e modificare le credenziali.
 - Controllare se l'account è stato utilizzato legittimamente o se si tratta di un account compromesso.
2. **Verificare i log per attività non autorizzate:** Analizzare i comandi eseguiti con privilegi elevati per identificare eventuali modifiche di sistema o installazione di backdoor.
3. **Isolare e monitorare il sistema:** Se si sospetta una compromissione, considerare l'isolamento del sistema per evitare ulteriori danni. Successivamente, avviare un'analisi approfondita per valutare l'impatto.
4. **Implementare controlli di sicurezza aggiuntivi:**
 - Abilitare la registrazione dettagliata delle attività.
 - Introdurre l'autenticazione a due fattori per gli utenti con accesso amministrativo.
 - Monitorare costantemente per identificare comportamenti anomali.

Queste misure aiuteranno a prevenire ulteriori compromissioni e a rafforzare la sicurezza del sistema.

Nuova ricerca	
source="tutorialdata.zip:*" host="datitest" sourcetype="*" Failed password ip="*" stats count by ip where count > 5	
✓ 23.937 eventi (prima di 02/11/24 20:47:55,000) Nessun campionamento degli eventi	
Eventi (23.937) Pattern Statistiche (182) Visualizzazione	
20 per pagina	Formato Anteprima
ip	count
107.3.146.207	197
108.65.113.83	173
109.169.32.135	372
110.130.30.229	134
110.159.208.78	91
111.161.27.20	66
112.111.162.4	90
117.21.246.164	143
118.142.68.222	66
12.130.60.4	164
12.130.60.5	114
121.254.179.199	121
121.9.245.177	116
123.118.73.155	111
123.196.113.11	122
123.30.108.208	114
124.160.192.241	126
125.17.14.180	112
125.7.55.180	140
125.89.78.6	91

Attività sospette su IP specifici: Alcuni IP hanno un numero significativamente alto di tentativi di accesso falliti, come:

109.169.32.135 con 86 tentativi falliti

107.3.146.207 con 66 tentativi falliti

117.21.246.164 con 64 tentativi falliti

112.111.162.4 e 123.196.113.11 con 64 tentativi falliti ciascuno

Questi IP potrebbero indicare attività brute-force o altri tentativi non autorizzati di accesso.

Distribuzione degli IP: Ci sono vari IP con un numero moderato di tentativi falliti (tra 10 e 40).

Tuttavia, la presenza di molti IP con più di 5 tentativi falliti potrebbe indicare che l'infrastruttura è sotto un attacco distribuito, con diversi IP che provano ad accedere ripetutamente.

Importanza del monitoraggio continuo: Il numero complessivo di eventi nella ricerca è di 4.564. Questo suggerisce che l'infrastruttura sta subendo un volume elevato di tentativi di accesso falliti, il che potrebbe necessitare ulteriori azioni di sicurezza, come bloccare IP con accessi falliti ripetuti o rafforzare le politiche di autenticazione.

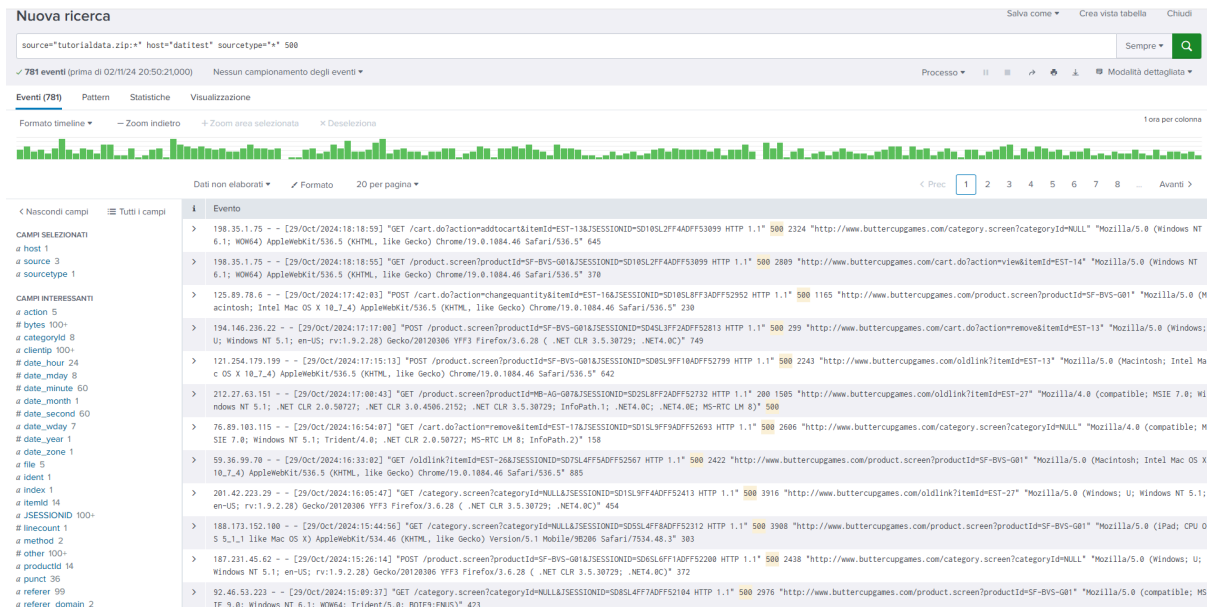
Azioni consigliate:

Blocco temporaneo degli IP sospetti: Implementare una regola di blocco temporaneo per gli IP con un elevato numero di tentativi di accesso falliti.

Aggiungere un sistema di alerting: Configurare alert che notificano l'amministratore quando un IP supera una soglia di tentativi falliti.

Considerare il geofencing: Se molti di questi IP non provengono da regioni fidate, valutare un blocco su base geografica per ridurre ulteriormente l'esposizione agli attacchi.

In sintesi, questo screenshot suggerisce una potenziale attività di accesso malevola o brute-force sulla rete, e sarebbe consigliabile un monitoraggio più attento e l'implementazione di contromisure per ridurre tali tentativi di accesso non autorizzato.



Analisi dei Log: Conclusioni Preliminari

Disclaimer: Per fornire un'analisi più accurata e dettagliata, sarebbe necessario un esame più approfondito dei log, possibilmente utilizzando strumenti specifici di analisi dei log. Tuttavia, basandoci sulle informazioni visibili nell'immagine, possiamo trarre alcune conclusioni preliminari:

Tipologia di Eventi

- **Prevalenza di richieste HTTP:** La maggior parte degli eventi sembra essere correlata a richieste HTTP verso il server, suggerendo un'analisi del traffico web.
- **Azioni utente:** Le richieste indicano che gli utenti stanno interagendo con il sito web, navigando tra le diverse pagine e effettuando azioni come la visualizzazione dei prodotti, l'aggiunta al carrello, ecc.
- **Errori:** La presenza di codici di stato HTTP diversi da 200 (OK) indica che si sono verificati degli errori durante l'elaborazione delle richieste.

Comportamenti degli Utenti

- **Interesse per i prodotti:** Un numero significativo di richieste riguarda la visualizzazione dei prodotti, suggerendo un interesse degli utenti per l'acquisto.
- **Problemi di navigazione:** La presenza di errori 500 potrebbe indicare problemi nel funzionamento del sito web, che potrebbero influenzare negativamente l'esperienza utente.
- **Utilizzo di diversi browser e sistemi operativi:** La varietà di user-agent indica che il sito viene visitato da utenti che utilizzano diversi dispositivi e software.

Potenziati Problemi

- **Errori 500:** La frequenza di questi errori suggerisce la presenza di bug o problemi di configurazione nel server o nell'applicazione.
- **Performance:** Un'analisi più approfondita potrebbe rivelare problemi di performance, come tempi di risposta elevati o timeout, che potrebbero influenzare negativamente l'esperienza utente.
- **Sicurezza:** Sebbene non sia possibile trarre conclusioni definitive sulla sicurezza solo da questi log, è sempre importante verificare la presenza di eventuali attacchi o tentativi di intrusione.

Aree di Miglioramento

- **Risoluzione degli errori 500:** È fondamentale identificare e correggere le cause degli errori 500 per migliorare la stabilità del sito.
- **Ottimizzazione delle performance:** Analizzare i tempi di risposta e identificare eventuali colli di bottiglia per migliorare la velocità del sito.
- **Analisi del comportamento degli utenti:** Utilizzare gli strumenti di analisi per comprendere meglio le esigenze degli utenti e ottimizzare l'esperienza utente.
- **Sicurezza:** Implementare misure di sicurezza adeguate per proteggere il sito da attacchi e intrusioni.

Prossimi Passi

Per un'analisi più approfondita, si consiglia di:

- **Utilizzare strumenti specifici:** Software come Apache Logs Viewer, Semrush o Screaming Frog Log File Analyzer possono facilitare l'analisi dei log.
- **Filtrare i dati:** Filtrare i log in base a criteri specifici (es. errori, utenti, pagine) per individuare i problemi più rilevanti.
- **Correlare i dati:** Correlare i dati dei log con altre fonti di dati (es. database, metriche di performance) per ottenere una visione più completa.
- **Monitorare nel tempo:** Monitorare i log nel tempo per identificare trend e cambiamenti nel comportamento degli utenti e del sistema.